4.5.1 Embedded PEPs in applications and gateways

The Policy Enforcement Point (PEP) can be deployed in various ways, depending on where enforcement is most effective within the system.

Figure 4.3 shows the PEP embedded directly in the application code. This is often the most straightforward approach. For instance, when Alice clicks the Team Reports tab in ACMEProject, the backend performs an inline access check by calling the PDP before returning data. This check, initiated at the moment a sensitive action is requested, serves as the application's PEP, enforcing a policy decision.

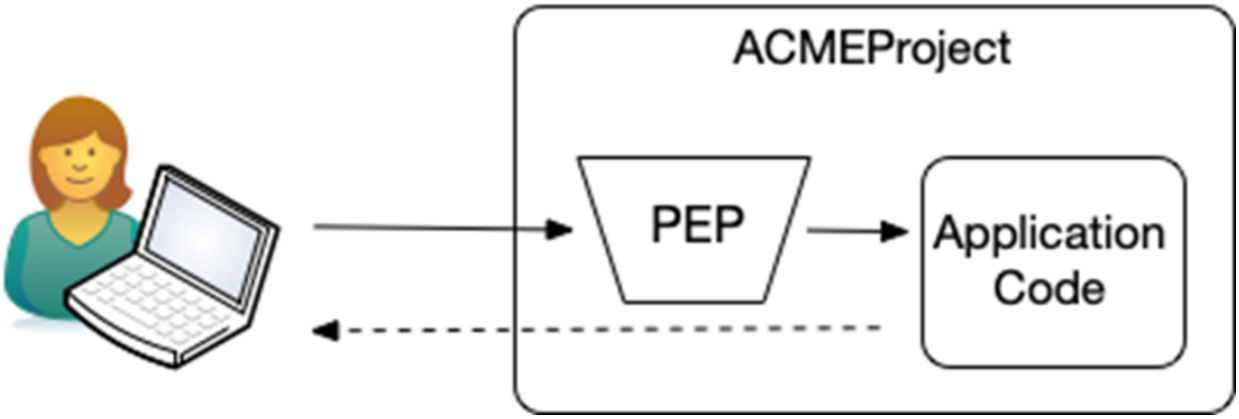


Figure 4.3 The Policy Enforcement Point (PEP) embedded in application code. In this model, the PEP is implemented directly within the ACMEProject backend, allowing it to evaluate access decisions with full visibility into the application's internal state and context.

Figure 4.4 shows the PEP situated in an API gateway, positioned before ACMEProject and other internal services. Many organizations use gateways like Kong, AWS API Gateway, or Envoy to centralize access control for multiple services. This approach enables uniform policy enforcement with minimal changes to application code. Additionally, it provides benefits such as centralized logging, auditing, and easier rollout of policy updates across services.